# EnterpriseOS

Business Requirements Document (BRD) + Software Requirements Specification (SRS)

Phase 5: Production Readiness, SaaS Billing and Operations

| Document control | Value |
|---|---|
| **Version** | 1.0 - Client review draft |
| **Status** | Proposed; client confirmation required |
| **Project** | EnterpriseOS - multi-tenant SaaS ERP |
| **Prepared for** | Client / Business Sponsor |
| **Stack** | React + TypeScript; Java Spring Boot; MySQL 8.4 LTS |
| **Prerequisite** | Approved and delivered Phase 4 baseline |
| **Date** | 11 November 2026 |
| **Approval** | Pending client sign-off |

Purpose: Determine client decisions, specify the proposed phase scope and provide verifiable approval and acceptance gates. Any default described here is a proposal, not a confirmed client requirement.

## 1. Executive Summary & Business Outcomes

Harden, validate and launch the platform with subscription controls, lifecycle administration, observability, recovery, security verification, QA automation, operational playbooks and contractual handover.

Phase 5 consumes the shared identity, tenancy and role model defined in Phase 1. Functional changes are implemented as new bounded modules in the same Spring Boot modular monolith. Existing security controls and audit records remain mandatory.

## 2. Prerequisites, Dependencies & Stakeholders

| Dependency | Entry requirement |
|---|---|
| **Prior phase** | Phase 4 released, accepted and regression-tested. |
| **Tenant & identity** | Active tenant context, membership validation, session security and permission model available. |
| **Reference data** | Departments, staff, currencies, policies and other dependent master data approved as applicable. |
| **Stakeholders** | Client sponsor, product owner, department SMEs, information security contact, UAT owner nominated. |
| **Delivery assets** | Source repository, staging environment, MySQL migration process, CI tests, email service available. |

Responsible stakeholders: Platform Owner, Tenant Billing Admin, Security Administrator, SRE/DevOps Engineer, Release Manager, Client UAT Lead, Support Operator.

## 3. Client Discovery - Required Inputs Before Scope Freeze

1. Is SaaS monetization in scope, and are payments processed or only tracked externally?
   Client answer / reference: _____

2. What plans, quotas, seats, trial terms, grace periods and suspension policy apply?
   Client answer / reference: _____

3. What are expected tenants, daily active users, peak requests and data volumes?
   Client answer / reference: _____

4. Which hosting, DNS, cloud accounts and legal/compliance owners are designated?
   Client answer / reference: _____

5. What target availability, p95 latency, RPO and RTO are contractually approved?
   Client answer / reference: _____

6. What support window, on-call escalation, incident severity and recovery drills are required?
   Client answer / reference: _____

7. What data residency, deletion, consent and retention obligations apply?
   Client answer / reference: _____

8. Who approves production go-live and who owns post-handover operations?
   Client answer / reference: _____

## 4. Functional Requirements - Traceability Baseline

### 4.1 SaaS Plans, Entitlements & Tenant Lifecycle

- P5-FR-0101 | Define subscription plans, seats, quotas and module entitlements
- P5-FR-0102 | Enforce plan limits using backend checks and client-approved grace policy
- P5-FR-0103 | Support trial activation, upgrade/downgrade and suspension workflows
- P5-FR-0104 | Maintain subscription and entitlement history and billing metadata
- P5-FR-0105 | Prepare customer-facing usage reports and renewal warnings

### 4.2 Production Security & Governance

- P5-FR-0201 | Threat-model sensitive business data and privileged flows
- P5-FR-0202 | Harden authentication, security headers, secrets and administrator operations
- P5-FR-0203 | Enforce tenant isolation regression and privilege escalation testing
- P5-FR-0204 | Implement retention, deletion/export processes subject to approved policy
- P5-FR-0205 | Review dependencies, security scan findings and remediation evidence

### 4.3 Monitoring, Reliability & Recovery

- P5-FR-0301 | Instrument structured logs, metrics, traces and health probes
- P5-FR-0302 | Configure error-rate, latency, queue backlog and availability alerts
- P5-FR-0303 | Define backup encryption, schedule, retention and restoration drills
- P5-FR-0304 | Run capacity tests with representative tenant/user/data distribution
- P5-FR-0305 | Provide incident severity classification, escalation and response runbooks

### 4.4 QA, Release & Client Handover

- P5-FR-0401 | Automate unit, integration, contract, end-to-end and regression suites
- P5-FR-0402 | Establish environment parity, migrations and rollback plans
- P5-FR-0403 | Run load, security, accessibility and disaster recovery verification
- P5-FR-0404 | Conduct business UAT, defect triage, release readiness and go/no-go
- P5-FR-0405 | Transfer source, deployment guides, admin handbook, support process and training

P0 = mandatory only after signed baseline. P1 = optional enhancement subject to separate client approval. Details such as calculation formulas, limits and country-specific rules must be signed off with worked examples.

## 5. Business Rules, Validation & Data Integrity

- BR-5-01: Entitlement enforcement occurs on backend operations and cannot rely only on hidden UI menus.
- BR-5-02: Subscription changes must not delete tenant data; retention and access transitions follow approved policy.
- BR-5-03: Payment collection and payment gateway compliance are excluded until provider, fee and liability scopes are signed.
- BR-5-04: Backups must be encrypted and tested via isolated restore; existence of backup files is not proof of recoverability.
- BR-5-05: Database migrations must be versioned and rehearse rollback/recovery for destructive changes.
- BR-5-06: Never claim enterprise certifications or guaranteed uptime without verified controls and signed SLAs.
- BR-5-07: Production secrets must not enter source control or client-visible logs; privileged actions need audit events.

## 6. Roles, Permissions & Segregation of Duties

Client must approve a role-permission matrix at action level (view, create, edit, approve, export, delete). Default-deny access is enforced by Spring Security and service-layer object authorization. UI restrictions never substitute for API enforcement.

| Role | Primary scope (proposed) |
|---|---|
| **Platform Owner** | Access to assigned module/actions only; final privileges require client-signed matrix. |
| **Tenant Billing Admin** | Access to assigned module/actions only; final privileges require client-signed matrix. |
| **Security Administrator** | Access to assigned module/actions only; final privileges require client-signed matrix. |
| **SRE/DevOps Engineer** | Access to assigned module/actions only; final privileges require client-signed matrix. |
| **Release Manager** | Access to assigned module/actions only; final privileges require client-signed matrix. |
| **Client UAT Lead** | Access to assigned module/actions only; final privileges require client-signed matrix. |
| **Support Operator** | Access to assigned module/actions only; final privileges require client-signed matrix. |

Control requirements: no unapproved self-approval, separation of preparer/approver where mandated, auditing of privileged changes, and tested cross-tenant isolation for all tenant-owned tables.

## 7. Business Workflows & User Journeys

- Flow 1: Platform admin provisions subscribed tenant -> entitlement checks enable licensed modules -> renewal/usage warning -> approved plan change.
- Flow 2: CI runs tests/scans -> staging deployment -> smoke/UAT -> production gate -> progressive release -> post-release monitoring.
- Flow 3: Incident detected by alert -> responder triages -> mitigates -> records cause -> validates recovery and preventive action.

- Flow 4: Restore drill uses encrypted backup -> verifies integrity and tenant boundaries -> records measured recovery point/time.

## 8. UI Screens & User Experience

| Screen group | Minimum proposed interface |
|---|---|
| **SaaS Plans, Entitlements & Tenant Lifecycle** | List/search/filter with pagination; create/edit/detail forms; permission-aware actions; review, error, empty and audit states |
| **Production Security & Governance** | List/search/filter with pagination; create/edit/detail forms; permission-aware actions; review, error, empty and audit states |
| **Monitoring, Reliability & Recovery** | List/search/filter with pagination; create/edit/detail forms; permission-aware actions; review, error, empty and audit states |
| **QA, Release & Client Handover** | List/search/filter with pagination; create/edit/detail forms; permission-aware actions; review, error, empty and audit states |

Common UX: accessible input labels, confirmation for irreversible actions, reliable error feedback, mobile-responsive layout, keyboard navigation, loading indicators, localization/currency/timezone where applicable. Wireframes require client approval.

## 9. Data Model & MySQL Entities

| Domain module | Proposed core tables (tenant-scoped unless global) |
|---|---|
| **SaaS Plans, Entitlements & Tenant Lifecycle** | subscription_plans, tenant_subscriptions, plan_entitlements, usage_counters, subscription_events, billing_documents |
| **Production Security & Governance** | security_events, data_requests, retention_jobs, access_reviews, security_review_records |
| **Monitoring, Reliability & Recovery** | operational_events, job_executions, backup_records, incident_records, service_level_reports |
| **QA, Release & Client Handover** | release_records, uat_cases, uat_executions, defect_records, change_requests, handover_checklists |

Schema principles: InnoDB foreign keys and appropriate unique constraints; tenant_id on tenant-owned business rows, UTC event timestamps, decimal types for money, effective-date history where necessary, optimistic versioning/locking for concurrent state changes, indexes based on measured queries, Flyway/Liquibase migrations. Do not silently cascade-delete finance, HR or audit evidence.

Client data decisions: retention, import source format, data stewardship and field-level privacy must be confirmed before database design approval. A detailed ERD, dictionary and migration/backfill plan are deliverables, not presumed existing artifacts.

## 10. REST API Contract - Illustrative Scope

| Method | Proposed path | Access |
|---|---|---|
| **GET** | /api/v1/platform/plans | Verified tenant role; platform-only where /platform |
| **POST** | /api/v1/platform/plans | Verified tenant role; platform-only where /platform |
| **GET** | /api/v1/platform/subscriptions | Verified tenant role; platform-only |

| | | |
|---|---|---|
| | | where /platform |
| **PATCH** | /api/v1/platform/subscriptions/{id} | Verified tenant role; platform-only where /platform |
| **GET** | /api/v1/org/subscription | Verified tenant role; platform-only where /platform |
| **GET** | /api/v1/org/usage | Verified tenant role; platform-only where /platform |
| **GET** | /actuator/health | Verified tenant role; platform-only where /platform |
| **GET** | /api/v1/platform/audit/security-events | Verified tenant role; platform-only where /platform |
| **POST** | /api/v1/platform/data-requests | Verified tenant role; platform-only where /platform |
| **GET** | /api/v1/platform/release-status | Verified tenant role; platform-only where /platform |

API standards: version /api/v1, DTO validation, consistent error envelope and correlation IDs, OpenAPI documentation, stable pagination/filters, idempotency for critical operations, conflict handling (409), throttling for sensitive endpoints and audit hooks.

## 11. Non-Functional & Security Requirements

| Category | Acceptance baseline / to confirm |
|---|---|
| **Availability** | Client to specify hosting/SLA, maintenance window and support hours; no implied uptime warranty. |
| **Performance** | Confirm p95 read/write latency and concurrent-user workload using realistic records and tenant distribution. |
| **Security** | TLS, authorization on every operation, secure secrets, validated uploads/exports, no password/token logging. |
| **Privacy** | Personal and financial data minimization; retention, consent, export and deletion policy signed by client. |
| **Reliability** | Backups and restore drill, concurrency testing, idempotent events, transactional state changes. |
| **Accessibility** | Keyboard-operable WCAG 2.2 AA target where explicitly agreed; browser matrix for Chrome/Edge/Firefox. |
| **Quality** | Unit, integration, API-contract, cross-tenant, regression and E2E tests in CI; security review gates. |
| **Observability** | Structured logs, metrics, health checks, alerts and audit trail without sensitive values. |

## 12. In Scope / Explicit Exclusions

| Included in Phase 5 | Deferred or excluded |
|---|---|
| **SaaS Plans, Entitlements & Tenant Lifecycle: agreed requirements** | Guaranteed uptime/security certification without independent verification |
| **Production Security & Governance: agreed requirements** | Production payment collection unless expressly approved and integrated |
| **Monitoring, Reliability & Recovery: agreed requirements** | Native Android/iOS apps and offline synchronization |
| **QA, Release & Client Handover: agreed requirements** | Multi-region active-active failover unless capacity and budget approved |
| **SaaS Plans, Entitlements & Tenant Lifecycle: agreed** | Continuous 24x7 support without a separate operational |

| | |
|---|---|
| **requirements** | agreement |

All third-party services, subscriptions, tax/legal assurance, external integrations and migration volumes require written scope and cost approval. AI, ML and generative AI features are explicitly out of scope for EnterpriseOS.

## 13. Acceptance Criteria & User Acceptance Testing (UAT)

- UAT-P5-01: Tenant plan quota is enforced server-side on all applicable creation endpoints.
- UAT-P5-02: Upgrade preserves data and enables new entitlements; downgrade follows agreed grace and retention rules.
- UAT-P5-03: A suspended subscription has precisely the approved access restrictions.
- UAT-P5-04: Backup restoration is verified with sample records and measured RPO/RTO.
- UAT-P5-05: Tenant isolation, RBAC and security regression suites pass on production-like staging.
- UAT-P5-06: Documented workload meets the signed latency/throughput objective; failure is recorded and remediated.
- UAT-P5-07: UAT critical defects are closed or formally waived, and customer signs the release gate.
- UAT-P5-08: Operational runbooks, admin training and access ownership are acknowledged.

Client approves UAT evidence with expected result, actual result, test data, screenshot/log reference, tester, date and disposition. Critical/high defects must be fixed or explicitly accepted with documented risk before production release.

## 14. Development Deliverables & Release Gates

| Stage | Deliverables | Exit gate |
|---|---|---|
| **Discovery** | Approved BRD/SRS, policy examples, role-permission matrix, dependencies | Requirements sign-off |
| **Design** | Wireframes, architecture notes, ERD/data dictionary, API spec, threat/edge-case review | Design sign-off |
| **Build** | React pages, Spring Boot modules, MySQL migrations, tests, audit hooks | Functional demonstration |
| **Verify** | Automated CI, security/regression tests, data migration checks, UAT runs | UAT approval |
| **Release** | Deployment, rollback/backup procedure, API docs, release notes, handover/training | Go-live authorization |

Commercial schedule, milestones and cost remain TBD. They depend on approved scope, policy complexity, third-party licensing, existing-data quality, staff capacity and client review cycles. Changes after sign-off use a documented change request with cost and schedule impact.

## 15. Assumptions, Risks & Open Decisions

| Topic | Risk / resolution |
|---|---|
| **Prior phase dependency** | Untested upstream permissions or data structures can invalidate this phase; require regression gate. |
| **Policy ambiguity** | Unapproved rule formulas or approval paths cause rework; require signed examples. |
| **Tenant privacy** | Cross-tenant and overprivileged exports are release blockers; negative tests required. |
| **Data migration** | Legacy fields may be incomplete/duplicated; profile and pilot |

| | |
|---|---|
| | migration before bulk import. |
| **Performance targets** | Capacity and realistic datasets are unknown; benchmark after workload approval. |
| **Compliance & legal** | Client owns jurisdictional requirements; engineering does not certify legal compliance. |
| **Scope changes** | Use issue/decision log and signed change order before adding new integrations/modules. |

## 16. Client Decisions & Requirements Checklist

☐ Is SaaS monetization in scope, and are payments processed or only tracked externally? Answer/reference: _____

☐ What plans, quotas, seats, trial terms, grace periods and suspension policy apply? Answer/reference: _____

☐ What are expected tenants, daily active users, peak requests and data volumes? Answer/reference: _____

☐ Which hosting, DNS, cloud accounts and legal/compliance owners are designated? Answer/reference: _____

☐ What target availability, p95 latency, RPO and RTO are contractually approved? Answer/reference: _____

☐ What support window, on-call escalation, incident severity and recovery drills are required? Answer/reference: _____

☐ Approved roles/permission matrix attached

☐ Wireframes, report examples and validation rules approved

☐ Hosting/security/retention/deployment requirements agreed

☐ UAT cases and authorized signatories agreed

## 17. Approval & Sign-off

Signatures indicate approval of the stated Phase 5 requirements baseline and acceptance conditions only. This document does not establish pricing, implementation warranties, or regulatory certifications.

| Role | Name / signature | Date |
|---|---|---|
| **Client Sponsor** | _____ | _____ |
| **Client Product Owner** | _____ | _____ |
| **Technical Delivery Lead** | _____ | _____ |

End of Phase 5 requirements document | Version 1.0 | Status: Client review draft